

МАША: серверный доступ, оплата и реклама

Технический план v10 - 27.08.2026

Главный принцип: без подтверждения сервера нельзя начать ни обычный, ни Direct IP-сеанс. Клиент бесплатный. Право оператора определяется единым Access / Entitlement Engine.

Участник	Действие	Обязательная проверка
Клиент	Публикует ID и heartbeat	Состояние устройства и привязка к сеансу
Оператор	Передаёт Device Key и ID клиента	Право доступа, лимиты, блокировки
Сервер Маши	Выдаёт session ticket и короткую lease	Подпись, срок, nonce, jti, binding
Принимающая Маша	Проверяет ticket до соединения	Тот же контроль для P2P, relay и Direct IP

Разрешено: сервер выдаёт короткоживущий подписанный ticket. После установления соединения сервер выдаёт и продлевает lease через heartbeat.

Не разрешено: новый сеанс не начинается. Если lease активного сеанса не продлена, сеанс завершается после установленного grace period.

Источники права

`payment`, `ad_reward`, `trial`, `promo` и `admin` создают унифицированные `access_grants`. Состояние оплаты не равно итоговому состоянию доступа.

Реклама как канал получения права

Приложение не может самостоятельно заявить `ad_watched=true`. Сервер создаёт одноразовый offer/nonce. Награда начисляется только после server-to-server webhook рекламной сети либо после серверной проверки receipt/token.

1. Обязательная модель авторизации

1.1. Решение сервера и fail-closed

- Любой новый сеанс вызывает `POST /v1/session/authorize`.
- Если сервер авторизации недоступен или ответ нельзя проверить, новый сеанс запрещён.
- Путь трафика не влияет на правило: P2P, relay и Direct IP используют одну авторизацию.
- Принимающее приложение проверяет подпись, срок и привязку права к конкретному сеансу.

1.2. Обязательные поля session ticket

Поле	Назначение
operator_device_id	Разрешённый экземпляр операторской Маши
client_id	Конкретное принимающее устройство
session_id	Конкретный сеанс
nonce, jti	Одноразовость и защита от повторного использования
iat, nbf, exp	Время выдачи, начала действия и окончания
kid	Ключ подписи и его ротация
constraints	Режим, лимиты, версия протокола и иные ограничения

1.3. Защита от повторного использования

`jti` регистрируется сервером и принимающей стороной. Ticket действует только для пары `operator-device/client`, конкретного `session_id` и `nonce` рукопожатия. Повторный ticket, другая цель или изменённые параметры отклоняются.

1.4. Lease активного сеанса

- После старта сервер создаёт короткую lease; приложение продлевает её heartbeat-запросами.
- Блокировка, отзыв права или исчерпание лимита запрещают продление.
- После пропуска heartbeat действует короткий серверный grace period, затем сеанс завершается.
- Точные интервалы heartbeat, TTL ticket и grace period являются серверными параметрами.

2. Данные, события и API

2.1. Основные таблицы

Таблица	Содержание
operators, devices	Device Key, состояние экземпляра, версия, блокировка
access_policies	Правила тарифа, группы и оператора
access_grants	Источник, тип, объём, valid_from, valid_until, статус
grant_consumption	Резервирование и списание права по сеансам
usage_sessions	authorize, start, heartbeat, finish, серверная длительность
session_tickets	jti, session_id, bindings, срок, состояние использования
billing_accounts	Расчётный статус отдельно от права доступа
payment_events	Исходные webhook-события и результат обработки
ad_reward_events	Provider, offer/nonce, receipt, награда, уникальность
audit_log	Решения доступа, отказы, блокировки и административные действия

2.2. Идемпотентность и доверие к событиям

- Каждый платёжный и рекламный webhook имеет уникальный provider event ID.
- Подпись провайдера проверяется до изменения состояния.
- Повторная доставка не создаёт повторный grant или повторное начисление.
- Сохраняются исходное событие, время получения, результат проверки и связь с созданным grant.

2.3. Основные API

- POST /v1/session/authorize - решение и выдача ticket.
- POST /v1/sessions/start , /heartbeat , /finish - lease, время и списание.
- GET /v1/access/status - итоговый доступ, причина и варианты восстановления.
- POST /v1/payments/create , POST /v1/webhooks/yookassa .
- GET /v1/ad-rewards/offers , POST /v1/ad-rewards/prepare .
- POST /v1/webhooks/ad/{provider} , POST /v1/ad-rewards/claim .

2.4. Учёт времени

Время услуги - период установленного сеанса удалённого управления от подтверждённого start до finish либо серверного закрытия после пропажи heartbeat. Сервер задаёт округление, минимальную единицу, правила аварийного завершения и одновременных сеансов. Повторные запросы не увеличивают время и списание.

3. Проверяемый план реализации

ТЕКУЩИЙ ЭТАП: 1.0 - ревизия и фиксация рабочей базы

Статус на 27.08.2026: серверный запрет ещё не подтверждён тестами. Последняя подтверждённая рабочая база - commit 922372ba7 . Сборка на b0f12214 не подтверждена. Preview-экраны Connect/Allow не считаются реализацией контроля доступа.

Этап	Результат	Критерий готовности
1.0 Ревизия базы	Зафиксировать рабочую ветку и отделить готовый код от preview/заготовок	Чистая воспроизводимая сборка базы и перечень применяемых изменений
1.1 Сервер authorize	Минимальный endpoint и подписанный ticket	Валидный запрос получает ticket; blocked/expired получает отказ
1.2 Проверка получателем	Подпись, exp, nonce, jti, bindings	Подмена и повторное использование отклоняются
1.3 Все пути соединения	Общий gate до P2P, relay и Direct IP	Ни один путь не обходит authorize
1.4 Lease и heartbeat	Продление и остановка активного сеанса	Отзыв права или потеря heartbeat завершают сеанс
1.5 Entitlement Engine	Единое решение по payment/ad/trial/promo/admin	Расчётный статус не блокирует действующий grant другого источника
1.6 Usage accounting	Start/heartbeat/finish, идемпотентность и списание	Повторные события не удваивают длительность или расход
1.7 Приёмочные тесты	Автоматические негативные и позитивные сценарии	Все обязательные тесты ниже проходят
1.8 Windows x64 CI	Новая установочная сборка	CI успешен, сборка установлена и испытана на двух устройствах

Правило перехода: следующий этап начинается только после сохранённого результата, проверки критерия готовности и контрольной точки в Git на `server` .

4. Обязательные приёмочные тесты этапа 1

1. **Active:** действующее право - сеанс разрешён.
2. **Blocked / expired:** новое соединение запрещено.
3. **Fail-closed:** сервер авторизации недоступен - новое соединение запрещено.
4. **Direct IP:** без действующего ticket соединение запрещено.
5. **Replay:** повторное использование ticket или jti запрещено.
6. **Wrong binding:** ticket другого клиента, оператора или session_id запрещён.
7. **Tamper:** изменение полей или подписи приводит к отказу.
8. **Lease revoke:** отзыв права прекращает активный сеанс после grace period.
9. **Heartbeat loss:** пропажа heartbeat закрывает сеанс и фиксирует серверную длительность.
10. **Idempotency:** повторные start/finish/webhook не создают двойного списания или grant.
11. **Alternative grant:** payment overdue не блокирует действующий ad_reward, promo или admin grant.
12. **Concurrent sessions:** сервер применяет заданный лимит одновременных сеансов.

Не входит в этап 1

Редизайн интерфейса, installer/auto-update, YooKassa UI, рекламный UI, защита бинарника и сайт не должны задерживать подтверждение серверного контроля. Их реализация начинается после прохождения тестов 1-12.

Порядок доказательства результата

- Коммит и точный SHA в репозитории на `server`.
- Лог автоматических тестов.
- Успешная Windows x64 сборка.
- Протокол ручного теста на операторском и клиентском устройствах.

5. Коммерциализация и продукт

5.1. YooKassa

Сервер создаёт платёж. Право изменяется только после проверенного `payment.succeeded`. Клиентское приложение не подтверждает оплату самостоятельно. Суммы, сроки отсрочки и правила тарифа задаются сервером.

5.2. Rewarded ads

Сервер выдаёт одноразовое предложение и поппе. Право начисляется только после доверенного подтверждения провайдера. Размер награды, страны, платформы, суточные лимиты и срок действия являются серверными параметрами.

5.3. Installer и автообновление

Стабильный Windows installer и механизм обязательного обновления позволяют закрывать ошибки, способы обхода и несовместимые старые версии.

5.4. Защита бинарника

Code signing, anti-tamper, контроль целостности и при необходимости обфускация являются вторым уровнем. Они не заменяют серверную авторизацию.

5.5. Интерфейс и бренд

Название, логотипы, иконки, тексты и пользовательские обозначения заменяются на «Маша». Юридические уведомления open-source сохраняются по требованиям лицензий. Connect / Allow показывают фактический статус сервера и доступные действия, не содержат зашитых коммерческих условий.

5.6. Сайт

Описание продукта, скачивание, краткая инструкция, условия использования, управление тарифом и доступные способы получения права. Для поиска - отдельные индексируемые страницы.

Утверждаемый итоговый принцип: цена, отсрочка, тарифы, рекламная награда и каналы получения права не фиксируются в коде Маши. Сервер принимает решение о доступе, выдаёт подписанное право на конкретный сеанс и контролирует продолжение активного сеанса через lease.